Incident Response Plan

ISO 27001:2022 — A.5.24, A.5.25, A.5.26, A.5.27, A.5.28

Documentnummer	ISMS-019
Versie	1.0
Classificatie	Vertrouwelijk
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Dit plan beschrijft hoe [Organisatienaam] beveiligingsincidenten detecteert, beoordeelt, behandelt en evalueert. Het doel is om schade te beperken, herstel te versnellen en herhaling te voorkomen.

2. Definities

Term	Definitie
Beveiligingsgebeurtenis	Een waargenomen activiteit die mogelijk relevant is voor informatiebeveiliging (bijv. mislukte inlogpoging)
Beveiligingsincident	Een gebeurtenis die daadwerkelijk leidt tot aantasting van vertrouwelijkheid, integriteit of beschikbaarheid
Datalek	Een beveiligingsincident waarbij persoonsgegevens zijn blootgesteld, verloren of gecompromitteerd

3. Incidentclassificatie

Ernst	Beschrijving	Voorbeelden	Responstijd
Kritiek	Directe, ernstige impact op bedrijfscontinuïteit of grote hoeveelheid data	Ransomware-uitbraak, massaal datalek, verlies van alle backups	Onmiddellijk (< 1 uur)

Hoog	Significante impact op één of meerdere systemen of vertrouwelijke data	Gecompromitteerd admin-account, gerichte phishing met dataverlies, server-inbraak	< 4 uur
Midden	Beperkte impact, geen data verloren maar wel risico	Succesvolle phishing zonder dataverlies, malware op werkstation (geïsoleerd), verloren USB-stick	< 8 uur
Laag	Minimale impact, gebeurtenis zonder directe schade	Verdachte e-mail gemeld, mislukte inbraakpoging geblokkeerd door firewall	< 24 uur

4. Incident Response Proces

```
Detectie → Beoordeling → Containment → Eradicatie → Herstel → Evaluatie
```

4.1 Fase 1 — Detectie en melding

Hoe worden incidenten gedetecteerd:

- Melding door medewerker (verdachte e-mail, ongebruikelijk gedrag)
- Automatische alert (SIEM, EDR, firewall, monitoring)
- Melding door externe partij (klant, leverancier, NCSC)
- Ontdekking tijdens audit of review

Meldprocedure:

1. Medewerker meldt onmiddellijk bij: [IT-helpdesk e-mail/telefoon] en/of [CISO contactgegevens]
2. CISO registreert het incident in het incidentregister
3. Bij vermoeden van datalek: onmiddellijk CISO én directie informeren

4.2 Fase 2 — Beoordeling (A.5.25)

De CISO beoordeelt binnen de responstijd:

Criterium	Vragen
Classificatie	Is het een gebeurtenis of een bevestigd incident?
Ernst	Kritiek / Hoog / Midden / Laag?
Omvang	Welke systemen, data en gebruikers zijn getroffen?
Datalek	Zijn er persoonsgegevens betrokken? Meldplicht AP?
Voortdurend	Is de aanval nog gaande of afgerond?

4.3 Fase 3 — Containment (A.5.26)

Doel: voorkomen dat het incident zich uitbreidt.

Actie	Verantwoordelijke
Gecompromitteerde accounts blokkeren	IT-beheer
Getroffen systemen isoleren van het netwerk	IT-beheer
Netwerktoegang beperken (firewall-regels aanscherpen)	IT-beheer
Wachtwoorden resetten voor getroffen accounts	IT-beheer
Bewijsmateriaal veiligstellen (logs, schijfimages, screenshots)	IT-beheer + CISO

4.4 Fase 4 — Eradicatie

Doel: de oorzaak van het incident wegnemen.

Actie	Verantwoordelijke
Malware verwijderen	IT-beheer
Kwetsbaarheid patchen die is uitgebuit	IT-beheer
Gecompromitteerde credentials vervangen	IT-beheer
Ongeautoriseerde accounts of toegang verwijderen	IT-beheer
Controleren of de aanvaller geen persistentie heeft achtergelaten	IT-beheer + CISO

4.5 Fase 5 — Herstel

Doel: systemen terugbrengen naar normale operatie.

Actie	Verantwoordelijke
Systemen herstellen vanuit schone backups	IT-beheer
Getroffen systemen terugplaatsen op het netwerk	IT-beheer
Functionaliteit verifiëren	IT-beheer
Verhoogde monitoring instellen (minimaal 72 uur)	IT-beheer
Gebruikers informeren dat systemen weer beschikbaar zijn	CISO

4.6 Fase 6 — Evaluatie (A.5.27)

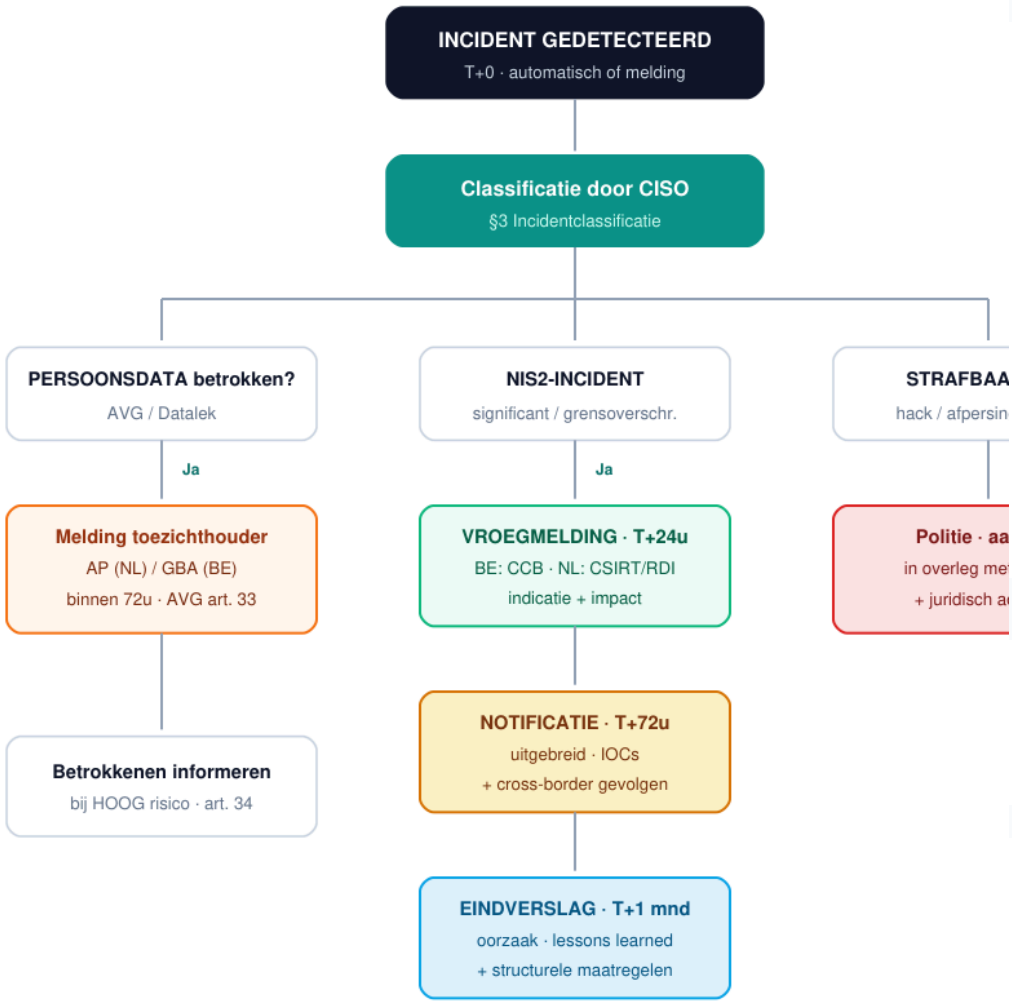
Binnen 2 weken na afsluiting van het incident:

Onderdeel	Beschrijving
Tijdlijn	Chronologisch overzicht van het incident

Oorzaakanalyse	Wat was de root cause?
Impact	Welke data/systemen waren getroffen?
Respons-evaluatie	Was de respons adequaat en tijdig?
Verbeterpunten	Welke maatregelen voorkomen herhaling?
Acties	Concrete verbeteracties met eigenaar en deadline

5. Meldplicht

5.0 Flowchart — wanneer, aan wie, binnen welke termijn



De drie sporen lopen parallel — één incident kan meerdere meldplichten triggeren.

5.1 Autoriteit Persoonsgegevens (AVG-datalek)

Bij een datalek met persoonsgegevens dat een risico vormt voor betrokkenen:

Actie	Termijn	Rechtsgrond
Melding aan toezichthouder	**Binnen 72 uur** na ontdekking	AVG art. 33
Melding aan betrokkenen	Onverwijld bij **hoog risico**	AVG art. 34
Registratie in datalek-register	Direct	AVG art. 33(5)

- **Nederland:** Autoriteit Persoonsgegevens (AP) — https://autoriteitpersoonsgegevens.nl
- **België:** Gegevensbeschermingsautoriteit (GBA) — https://www.gegevensbeschermingsautoriteit.be
- CISO is verantwoordelijk voor de melding (coördinatie + indiening).

5.2 NIS2-meldplicht — CSIRT / toezichthouder

Bij een **significant incident** zoals gedefinieerd in NIS2 (art. 23):

Fase	Termijn	Inhoud
Vroegmelding	Binnen **24 uur** na kennisname	Vermoeden van kwaadwilligheid? Cross-border? Eerste impact-beoordeling.
Incident-notificatie	Binnen **72 uur**	Uitgebreide beschrijving: aard, omvang, impact, afgenomen maatregelen, cross-border gevolgen.
Tussenrapport	Op verzoek	Status-update bij aanhoudend incident.
Eindrapport	Binnen **1 maand** na incident	Definitieve analyse: oorzaak, verloop, maatregelen, impact grensoverschrijdend.

Aan wie melden per land:

Land	Toezichthouder / CSIRT	Contact
België	Centrum voor Cybersecurity België (CCB)	https://atwork.ccb.belgium.be (portaal)
Nederland	Rijksinspectie Digitale Infrastructuur (RDI) + sector-toezichthouder + NCSC-NL	cert@ncsc.nl · 070-751 55 55

Wat is een "significant incident" onder NIS2? Incident dat:

- Een ernstige operationele verstoring kan veroorzaken of financiële verliezen;
- Gevolgen heeft/kan hebben voor andere natuurlijke of rechtspersonen door aanzienlijke materiële of immateriële schade.

5.3 Politie

Bij vermoeden van strafbare feiten (hacken, afpersing/ransomware, fraude, sabotage):

- Aangifte in overleg met directie en juridisch adviseur
- Bewijsmateriaal bewaren volgens forensische procedure (A.5.28) — geen systemen wipen zonder eerst forensische image
- NL: Landelijke Meldpunt Internetoplichting (LMIO) / Politie-cybercrime unit
- BE: Federal Computer Crime Unit (FCCU) — https://www.police.be

6. Incidentregister

ID	Datum	Melder	Beschrijving	Ernst	Status	Oorzaak	Datalek?	Meldplicht AP?
INC-001	[Datum]	[Naam]	[Beschrijving]	[K/H/M/L]	[Open/In behandeling/Afgesloten]	[Root cause]	[Ja/Nee]	[Ja/Nee/N.v.t.]

7. Contactlijst

Rol	Naam	Telefoon	E-mail / URL
CISO	[Naam]	[Nummer]	[E-mail]
IT-beheer (primair)	[Naam]	[Nummer]	[E-mail]
IT-beheer (backup)	[Naam]	[Nummer]	[E-mail]
Directie	[Naam]	[Nummer]	[E-mail]
Externe forensisch partner	[Naam bedrijf]	[Nummer]	[E-mail]
Nederland — AP (AVG-datalek)	—	070-8888 500	autoriteitpersoonsgegevens.nl
Nederland — NCSC (NIS2-CSIRT)	—	070-751 55 55	cert@ncsc.nl
Nederland — RDI (NIS2-toezichthouder)	—	070-314 90 00	rdi.nl
Nederland — Politie (cybercrime)	—	0900-8844	—
België — GBA (AVG-datalek)	—	+32 2 274 48 00	gegevensbeschermingsautoriteit.be
België — CCB (NIS2-CSIRT + toezicht)	—	—	atwork.ccb.belgium.be
België — FCCU (cybercrime)	—	101	police.be

8. Testen

Test	Frequentie	Methode
Tabletop-oefening (scenario-doorloop)	Jaarlijks	Scenariobespreking met CISO, IT, management
Technische oefening (simulatie)	Jaarlijks (aanbevolen)	Gesimuleerde aanval met technische respons
Contactlijst verificatie	Halfjaarlijks	Controle of contactgegevens actueel zijn

9. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]